CONFIDENTIAL **MOCK EXAM 2026**

GENERIC UNIVERSITY FINAL EXAMINATION

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 4 printed pages

PART A (80 MARKS)

QUESTION 1

a) State TWO (2) characteristics of a Trojan horse as a type of malware.

(2 marks)

b) Explain six (6) techniques by which malware infects host programs or propagates across systems, as described in the lecture material on software security.

(6 marks)

QUESTION 2

a) List two ways in which morals, ethics and laws differ from one another as forms of guidance for conduct.

(2 marks)

b) Refer to your answer in (a). Discuss how a professional code of ethics and conduct guides a computing professional's behaviour, using the ACM code as your example. Your discussion should cover six distinct requirements of such a code.

(6 marks)

QUESTION 3

a) Explain the Chinese Wall model as a formal security model, stating the concern it is designed to address and how its access decisions differ from static policies.

(2 marks)

b) Describe six aspects of access control structures, covering the access control matrix, access control lists and capabilities, including the advantages and disadvantages of the matrix and of ACLs.

(6 marks)

QUESTION 4

a) Explain how the classes of threats described in the lecture affect the confidentiality, integrity and availability of information assets.

(2 marks)

b) State SIX (6) facts about the Samy worm and the cross-site scripting (XSS) attack it exploited, covering how the malicious script was injected, how it spread to other users, and why unfiltered user input enables such attacks.

(6 marks)

QUESTION 5

a) Explain what a buffer overflow is and how it can be exploited, referring to the behaviour of strcpy() and the effect on the stack.

(2 marks)

a) Describe six Windows security mechanisms and features, covering how user accounts and objects are managed, how access control is applied, how subjects obtain credentials, what Active Directory organises, how access rights are encoded, and why the complexity of these mechanisms can itself be a risk.

(6 marks)

QUESTION 6

a) State the two stages of the biometric authentication process and, for each stage, state the activities it involves.

(2 marks)

b) Discuss biometric technologies by categorising the types of biometric applications available today and, for each category, giving examples. Then discuss two disadvantages associated with specific biometric technologies.

(6 marks)

QUESTION 7

a) State TWO (2) limitations of misuse detection systems when used to detect attacks.

(2 marks)

b) A security analyst is preparing a briefing on malware threat classes and the countermeasures that address them. Explain the threat posed by rootkits, spyware and adware, and the countermeasures or defensive considerations associated with each.

(6 marks)

QUESTION 8

a) Explain how the chain of trust works in the Trusted Computing architecture, with reference to the TPM and the measurement of each stage.

(2 marks)

b) Compare the two primary system components of the Next Generation Secure Computing Base, namely the Nexus and the Nexus Computing Agent, in terms of their roles and characteristics. Provide six distinct points of comparison.

(6 marks)

QUESTION 9

a) Explain two password security controls that can be applied to password files and accounts in order to strengthen password-based authentication.

(2 marks)

b) Explain the mechanisms of Kerberos, smartcards and single sign-on as alternative authentication approaches, covering the motivation for single sign-on, the categories of single sign-on solutions, how a Kerberos user login establishes a secret key, and the role of smartcards.

(6 marks)

QUESTION 10

a) A network administrator is deploying a Network-Based Intrusion Detection System (NIDS) to protect an organization's critical servers. List TWO (2) typical locations where NIDS sensors should be placed.

(2 marks)

b) A company wants to strengthen its network defences before deploying monitoring tools. State SIX (6) preventive network security mechanisms and, for each, briefly describe what it does.

(6 marks)

PART B (20 MARKS)

QUESTION 1

a) Explain five ways in which a voluntary professional code of ethics can shape the ethical impact of the technology that computing professionals build and deploy, and note the limits of relying on such a code.

(5 marks)

b) Using the hospital scenario, explain five ethical concerns that the programmer should raise with management regarding the privacy of patients' information and the organization's responsibility for it.

(5 marks)

QUESTION 2

a) Discuss the goals of access control and the role of a reference monitor in making authorization decisions, then explain how the Chinese Wall model constrains access through its simple security rule and its write property.

(5 marks)

b) State five key security models and, for each, the distinguishing feature given in the lecture, including the model that identifies conflicts of interest and the model that adds integrity verification.

(5 marks)

END OF QUESTION PAPER